Table of Contents

AD Tiering (A Work in Progress Guide) 2
Concepts Explained: 2
Configuration Baseline: 2
OU Structure: 2
Security Groups: 4
Administrator Accounts: 5
User Accounts: 5
Group Policy Objects: 6
Scheduled Tasks: 10

AD Tiering (A Work in Progress Guide)

This guide is a work in progress in an attempt to create a standardized starting point for AD-Tiering. The goal is to have it reviewed and used by additional consultants, so that we have a unified method of approach to how we wish to do AD-Tiering.

Concepts Explained:

At its core, AD Tiering is basically 3 core OUs, 4 types of Security Groups, and 3 GPOs, that are used to structure Tiering 'levels' in the AD infrastructure.

Configuration Baseline:

OU Structure:

The OU Structure at its core will always have the following Ous:

There are a few general rules to Tiering.

1. Tier 0 is considered the 'Highest Level' for security
2. Tier 2 is considered the 'Lowest Level' for security
3. Administrators can ONLY administer the Tier they exist in, so a Tier 0 Admin, can only Admin in Tier 0
4. If an Admin needs to have administrative rights across multiple Tiers, then they need an Admin for each Tier.
5. A Lower-Level Tier may use services from a Higher-Level Tier, but may not directly logon to the Higher-Level tiers directly (the exception to the rule is RDS/Citrix Environments)
6. It is important that what we do in one tier, does not breach the idea of separating Services, Admins, and Users by Tier.

Each tier has its own usage outline which is described below:

- Tier 0
    - This tier is for Identity Services Only, or Critical Systems that have a direct impact on Identity, or Identity Services. Additionally, with heavy consideration, critical systems may be put her, so long as Users do not directly touch these.
    - Examples of such services would include:
        - Domain Controllers
        - PKI
        - ADFS
        - NPS Servers used for MFA (Access for Admins via VPN if compromise happens – this is debatable, but if lets say Tier 1 is compromised, how would an admin logon if the NPS server was in Tier 1 and compromised?)
        - Systems that may change Passwords or Setup Users in the AD should probably be placed here.
- Tier 1
    - This tier is where Services exist, and is where most Server Infrastructure will reside.

    - Examples of such services would include:
        - SQL
        - FileServers
        - Remote Desktop/Citrix Environments
        - Application Servers
        - Other Services used to shape the working infrastructure.
- Tier 2
    - This tier is for Users & Devices
    - This tier has the largest chance for being compromised, so it is important that AD Tiering rules & regulations are handled properly to ensure there is no Breach in Tier structure.

NOTE: When reviewing the Customer's existing setup, you need to 'Clone' their OU Structure into the correct Tiers. What this means, is you need to evaluate the different OUs, and create a similar OU scheme in the correct Tier. This is so it becomes easier to migrate later, so you will move from Source to Destination OU with same name, just under the correct tier.

NOTE: Additionally, you will need to review the GPOs on the Source OUs, and make an EXACT setup of those GPOs on the new OUs in the Tier model Remember to review the GPO Priority Order, and ensure that this is the same as well.

NOTE: When setting up OU structure, it is critical to place GPOs in a way to reduce GPO in heritance as much as possible, this is because we should NEVER us Block Inheritance on an OU in a AD Tiering Setup. The reason for this is, we will block important GPOs like the ones responsible for the Tiering Setup, and the Default Domain GPO.

Security Groups:

As mentioned earlier, there are 4 types of security groups that will be used in AD Tiering structure:

1. User Groups by Tier (Manually Created)
    a. ```
       Tier0Users
       Tier1Users
       Tier2Users
       ```
    b. These groups will be used for ALL users in that tier. This includes but is not limited to:
        i. Administrators
        ii. Users
        iii. Service Accounts
    c. If it is an account that is used for a specific tier in any kind of way, it must be in the User Group for that tier.

2. Local Admin_All Group (Manually Created)
    a. ```
       SG_LocalAdmin_T0_All
       SG_LocalAdmin_T1_All
       SG_LocalAdmin_T2_All
       ```
    b. These Groups are for the Administrators of the Tiers
    c. These will be applied via GPO to the Local Admin Groups for that Tier

3. Local Admin Groups by Server (Created & Managed by GPO)
    a. These will be created for each Server that they GPO affects for a specific Tier

4. Remote Desktop Users Groups by Server (Created & Managed by GPO)
    a. These will be created for each Server that they GPO affects for a specific Tier

Administrator Accounts:

With the OU Structure, and Security Groups created you can make Administrator User Accounts. Below is an outline of how to place them in groups.

1. Domain Admins – we need to remove all user accounts from this Group, and move Administrators over to their new accounts Tiered Admin Accounts. So their old Domain Admins need to be retired.
    a. Do this first, before making huge changes in the AD – this is to ensure Admins are working in their new accounts
    b. We want to ensure 'Administrator' is not being used anywhere in the domain so we can remove it from the Domain Admins group
2. AdmT0admin – when creating administrators, follow the AdmT0 context, and end with user initials.
    a. For T0 admins, add them to the following groups:
        i. Domain Admins
        ii. SG_LocalAdmin_T0_All
        iii. SG_Tier0Users
        iv. Domain Users
3. Admt1admin - when creating administrators, follow the AdmT1 context, and end with user initials.
    a. For T1 admins, add them to the following groups:
        i. SG_LocalAdmin_T1_All
        ii. SG_Tier1Users
        iii. Domain Users
4. AdminT2admin - when creating administrators, follow the AdmT2 context, and end with user initials.
    a. For T2 admins, add them to the following groups:
        i. SG_LocalAdmin_T2_All
        ii. SG_Tier2Users
        iii. Domain Users

User Accounts:

User Accounts follow the same logic as Administrator Accounts, you simply don't add them to Administrator Groups. It is important to understand User Accounts are bound to Tier2 by default, and should never be placed in groups related to higher tiers!!

1. UserAccount – Should only target Tier 2 configurations
    a. For Users in T2, add them to the following groups:
        i. SG_Tier2Users
        ii. Domain Users

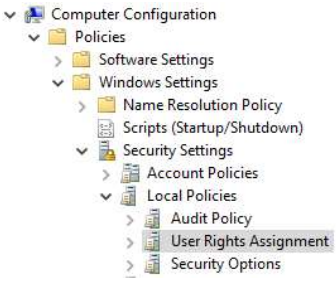
Group Policy Objects:

It is in the GPOs that the magic happens. By allowing and denying the SG_Tier#User groups to objects under a specific Tier# OU, we shape what users have, and don't, have access to.
At its core, there are 3 GPOs that will manage the Core Setup of our AD Tiering configuration.

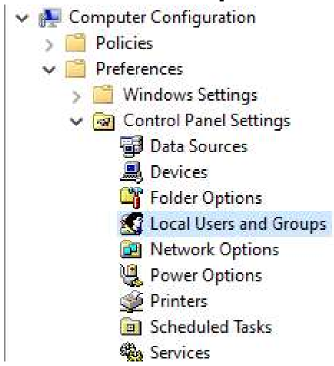
```
C_Tier0_Base_Protection
C_Tier1_Base_Protection
C_Tier2_Base_Protection
```

Below will be a GPO outline for each environment:
Each GPO will be managing Local Policies/User Rights Assignments and Local Users and Groups in this GPO

- **User Right Assingments location:**



- **Local Users and Groups location:**



C_Tier0_Base_Protection:

The following outlines the GPO setup for Tier0

User Rights Assignment:

Deny log on as a batch job Properties

Security Policy Setting | Explain

Deny log on as a batch job

☑ Define these policy settings:

Guests
HUSET\SG_Tier1Users
HUSET\SG_Tier2Users

Deny log on as a service Properties

Security Policy Setting | Explain

Deny log on as a service

☑ Define these policy settings:

Guests
HUSET\SG_Tier1Users
HUSET\SG_Tier2Users

Deny log on locally Properties

Security Policy Setting | Explain

Deny log on locally

☑ Define these policy settings:

Guests
HUSET\SG_Tier1Users
HUSET\SG_Tier2Users

Deny log on through Remote Desktop Services Properties

Security Policy Setting | Explain

Deny log on through Remote Desktop Services

☑ Define these policy settings:

Guests
HUSET\SG_T0_ServiceAccounts
HUSET\SG_Tier1Users
HUSET\SG_Tier2Users

Local Group: Administrators:

Remote Desktop Users (built-in) (Order: 2)

Local Group

Action	Update
Properties	
Group name	Remote Desktop Users (built-in)
Delete all member users	Disabled
Delete all member groups	Disabled
Add members	
HUSET\SG_LocalAdmin_T0_All	[redacted]
%DomainName%\SG_RDP_%ComputerName%	

Local Group: Remote Desktop Users:

Remote Desktop Users (built-in) (Order: 2)

Local Group

Action	Update
Properties	
Group name	Remote Desktop Users (built-in)
Delete all member users	Disabled
Delete all member groups	Disabled
Add members	
HUSET\SG_LocalAdmin_T0_All	[redacted]
%DomainName%\SG_RDP_%ComputerName%	

C_Tier1_Base_Protection:

The following outlines the GPO setup for Tier1

User Rights Assignment:

Deny log on as a batch job Properties

Security Policy Setting | Explain

Deny log on as a batch job

☑ Define these policy settings:

Guests
HUSET\Domain Admins
HUSET\Enterprise Admins
HUSET\Schema Admins
HUSET\SG_Tier0Users
HUSET\SG_Tier2Users
Local account and member of Administrators group

Deny log on as a service Properties

Security Policy Setting | Explain

Deny log on as a service

☑ Define these policy settings:

Guests
HUSET\Domain Admins
HUSET\Enterprise Admins
HUSET\Schema Admins
HUSET\SG_Tier0Users
HUSET\SG_Tier2Users
Local account and member of Administrators group

Deny log on locally Properties

Security Policy Setting | Explain

Deny log on locally

☑ Define these policy settings:

Guests
HUSET\Domain Admins
HUSET\Enterprise Admins
HUSET\Schema Admins
HUSET\SG_Tier0Users
HUSET\SG_Tier2Users

Deny log on through Remote Desktop Services Properties

Security Policy Setting | Explain

Deny log on through Remote Desktop Services

☑ Define these policy settings:

Guests
HUSET\Domain Admins
HUSET\Enterprise Admins
HUSET\Schema Admins
HUSET\SG_T1_ServiceAccounts
HUSET\SG_Tier0Users
HUSET\SG_Tier2Users
Local account and member of Administrators group

Local Group: Administrators:

Administrators (built-in) (Order: 1)	
Local Group	
Action	Update
Properties	
Group name	Administrators (built-in)
Delete all member users	Enabled
Delete all member groups	Enabled
Add members	
HUSET\SG_LocalAdmin_T0_All	[illegible]
%DomainName%\SG_LocalAdmin_%ComputerName%	

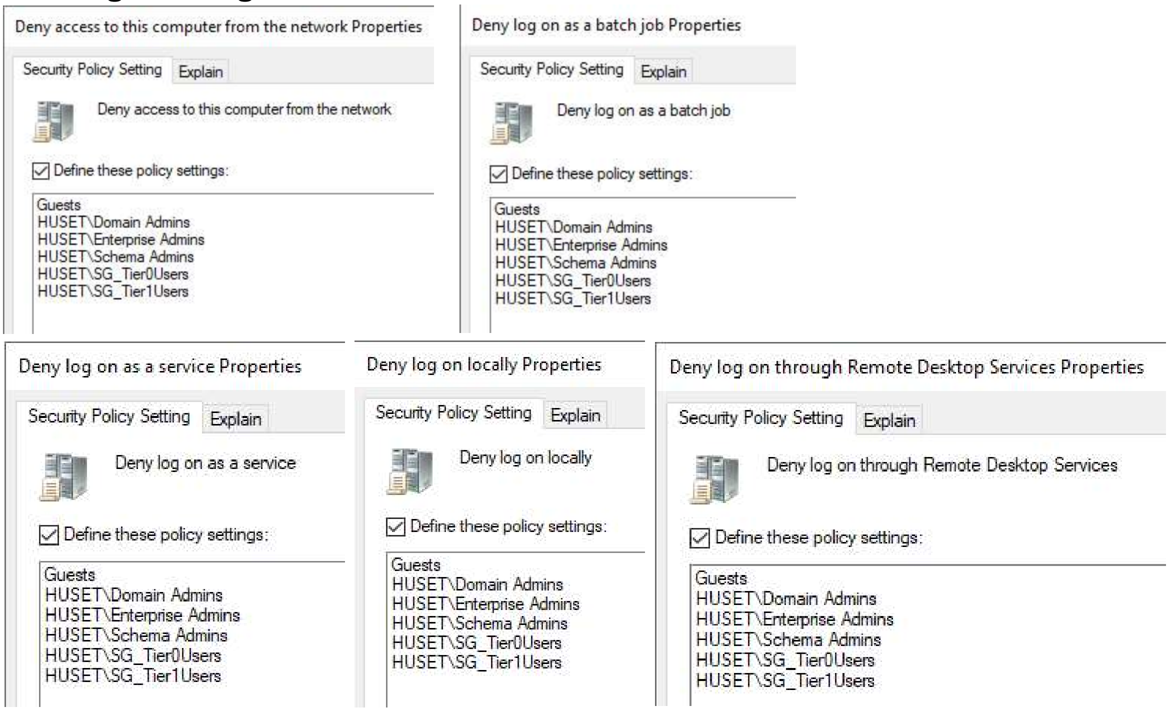
Local Group: Remote Desktop Users:

Administrators (built-in) (Order: 1)	
Local Group	
Action	Update
Properties	
Group name	Administrators (built-in)
Delete all member users	Enabled
Delete all member groups	Enabled
Add members	
HUSET\SG_LocalAdmin_T0_All	[illegible]
%DomainName%\SG_LocalAdmin_%ComputerName%	

C_Tier2_Base_Protection:

The following outlines the GPO setup for Tier1

User Rights Assignment:



Local Group: Administrators:

This is up for debate based on the customer's workflow. You can:

1. Deploy the SG_LocalAdmin_T2_All group across all devices, to ensure T2 admins have access.
2. Use LAPS as a way to access user devices when needed
3. Deploy local admin groups per device (this will make a lot of groups)
4. Ultimately this portion is something the Consultant needs to consider in dialog with the Customer, or regarding the workflow.

Local Group: Remote Desktop Users:

1. This isn't really needed for client devices

Scheduled Tasks:

There are a few Scheduled Task-Scripts that need to be run on the primary Domain Controller. These Scheduled Tasks are designed to help move groups created from GPOs into the desired OU to keep things organized via automation. The other Scheduled tasks will move Users found in a Tier into the correct User Group.

These Scheduled tasks will have information to come in the next version of this document.